

Answer Part 1

Repository and collaboration

Phanuwit Butchari - 67070501070 (auto4496)
Peer: Pitchai Chadchuangchot - 67070501068 (Datakung)

Student acceptance pending. Final-main technical evidence is complete. The student still needs to read/adapt the Reflection and confirm the final human visual checks before this copy is submitted. Issue #30 remains open until then.

[Repository](#) | [Project board](#) | [Release acceptance #30](#)

Application source of truth: merged main b3a65949f3fad3c84ffabbe01707db0d929686f0. Feature branches were reviewed into lab3-staging; PR #36 integrated staging into main on 2026-09-26. Final-main runs and screenshot metadata in this report identify this exact source, rather than relabelling staging results.

Rendered reviewer record - current completed reviews

Condensed from [reviewer.md](#) and the [actual GitHub review records](#). Dates below are UTC.

PR	Scope	Approval	Merge
#31	[Lab 3] Define engineering contract and Zen Green UI plan	Datakung 2026-09-13T04:47:10Z	ec5deceea1e0
#32	Lab 3: Authentication and Requester Foundation (#26)	Datakung 2026-09-15T07:32:04Z	1bf45888cdf4
#33	[Lab 3] IT Staff ticket workflow and conversations	Datakung 2026-09-16T07:59:36Z	f13469cdbbcb
#34	feat(lab3): add administrator user management and account safety	Datakung 2026-09-22T14:30:11Z	2c6f79938ec1
#35	Verify Lab 3 integration and preserve dialog keyboard focus	Datakung 2026-09-25T18:07:08Z	e685eec892d2
#36	[Lab 3] Release integrated service desk to main	Datakung 2026-09-26T10:53:14Z	b3a65949f3fa

Real findings and responses: [#31 board/document alignment](#); [#32 CSRF refresh and intended-route recovery](#); [#33 lost-response conversation recovery](#); [#34 dirty-navigation protection](#) and [specific browser success assertions](#). Corrections preceded the peer approvals above. Author responses to #34: [navigation fix](#), [assertion fix](#). PR #35 independently repeated all 389 tests, 17 browser journeys, both builds and 109 image checksum checks. PR #36 approved integration with a [non-blocking migration-runbook suggestion](#); the corrected post-merge runbook is linked in Part 3.

Repository history

```
* b3a6594 Merge pull request #36 from auto4496/lab3-staging
| \
| * e37379b docs(lab3): record release PR 36 handoff and remaining acceptance
| * 58e1efb docs(lab3): add inspected release review PDF and provenance
| * aab88a1 docs(lab3): refine report tables and directory links
| * 747e0a6 docs(lab3): prepare release checklist and reproducible review report
| * 775e727 docs(lab3): close issue 29 after independent approval and merge
| * e685eec Merge pull request #35 from auto4496/codex/lab3-5-system-verification
| \
| | * 3d251ce docs(lab3): record integrated verification and curated visual evidence
| | * 5a0934e test(lab3): complete dialog API stub for modal cleanup
| | * 08d3711 test(lab3): verify integrated workflows and preserve modal keyboard focus
| | /
```

```

| * 2c6f799 Merge pull request #34 from auto4496/codex/lab3-4-user-administration
| |\
| | * c84ad03 fix(lab3): guard dirty account navigation and scope success assertions
| | * 88922cb docs(lab3): record administrator review handoff
| | * 25776f3 feat(lab3): add administrator user management with account safety
| | /
| * f13469c Merge pull request #33 from auto4496/codex/lab3-3-staff-workflow
| |\
| | * 37d5cd5 fix(lab3): reconcile latest conversation page after uncertain posts
| | * 4196fc9 docs(lab3): record verified staff workflow review handoff
| | * f8c1f49 feat(lab3): implement staff ticket workflow and conversations
| | /
| * 1bf4588 Merge pull request #32 from auto4496/codex/lab3-2-auth-requester
| |\
| | * 82d7019 fix(auth): recover rejected CSRF and restore permitted destinations
| | * 7f2a5dd docs(lab3): confirm foundation issue development link
| | * bb296b6 docs(lab3): record foundation PR and review handoff
| | * 3c42711 feat(lab3): add authentication and requester foundation (#26)
| | /
| * ec5dece Merge pull request #31 from auto4496/codex/lab3-1-engineering-contract
| /|
| * 609b2ed docs(lab3): address contract workflow review
| * 923648d docs(lab3): record contract PR and validation handoff
| * b006797 docs(lab3): define engineering contract and six-issue plan
| /
* f124c72 Merge pull request #24 from auto4496/codex/lab2-release-evidence
|\
| * 9c6be4a docs(lab2): finalize release evidence
| * a53e0d1 docs(lab2): prepare final release evidence
* | a0a4d32 Merge pull request #23 from auto4496/lab2-staging
| |\
| * 73c0ecb Merge pull request #22 from auto4496/feature/lab2-6-quality-evidence
| |\
| | * 93eca5d docs(lab2): clarify e2e evidence capture
| | * 9dd392d fix(lab2): isolate e2e cleanup and evidence capture
| | * 7b547cf docs(lab2): record issue 17 review handoff
| | * 84be663 docs(lab2): record quality and visual evidence
| | * 8257c36 test(lab2): expand grading state evidence
| | * 022cdb3 test(lab2): add release readiness browser coverage
| | /

```

Setup, ignore rules and structure

[README setup/build/test instructions](#) and [.gitignore](#) retain environment files, initial-password files, dependencies, uploads and generated temporary output outside version control. Only curated evidence is published. The main screenshot manifest is refreshed separately in the final evidence bundle.

```

client/src, client/tests      - React screens and component tests
server/src, server/tests     - API, authorization and regression suites
server/prisma                - schema, committed migrations and seed
e2e/lab-02, e2e/lab-03       - retained and new browser journeys
docs/lab-03                  - reviewed specifications and history
artifacts/lab-03             - curated visual and release evidence
.env.example, .env.test.example - local configuration templates

```

Work items #25-29 are complete. #30 tracks post-merge acceptance; its final status must match the actual student acceptance rather than the earlier automatic close on merge.

Answer Part 2

Specification and acceptance contract

The contract was reviewed in PR #31 before feature implementation. [Original contract commit](#). The specification below is the complete reviewed source on main, including original planning and Definition of Done checkboxes. Current execution status is established by Parts 1, 3 and 9; original contract checkboxes are not a claim of a student action.

Rendered specification.md, complete contract. [Source document](#).

Lab 3 Sprint Engineering Specification

Status (2026-09-26): Contract approved in PR #31; implementation and integrated verification are peer-approved and merged through PR #35. Issue #30 is preparing the staging-to-main release. Final-main acceptance and the final Definition of Done sign-off remain pending. Dated historical plans are retained; current execution evidence is in [system-verification.md](#) and remaining work in [release.md](#).

Source: CPE 334 Lab 3 handout, "TokTickIT Users, Roles, IT Staff Ticketing, and Admin Screens", 18 pages. This contract interprets the handout; explicit exclusions take precedence over extra controls in its illustrative screenshots.

Baseline: completed Lab 2 main at f124c72. Lab 3 work is isolated from unfinished local Lab 2 report edits.

1. Sprint Goal

Replace temporary requester selection with authenticated accounts and backend authorization, preserve existing Requester tickets and attachments, deliver the first operational IT Staff queue and ticket workflow, and provide small, usable Administrator account-management screens in the existing Zen Green design language.

2. Stakeholder Request

Requesters sign in and continue managing their own reports. IT Staff find, accept, prioritize, discuss, and progress tickets. Administrators maintain one-role user accounts and initial passwords. Initial-password users must choose a new password before accessing application data. Public conversation and private operational notes remain clearly separated in both UI and API.

3. Scope

Included: login/logout/current user/password change; role-specific navigation; server-side identity, role and ownership checks; data migration and local seed; Requester regression and resolution indication; staff queue/detail/assignment/priority/status; append-only comments and notes; minimal user administration; traceable tests, responsive/visual review and course evidence.

Excluded: registration, invitations, password-reset email, MFA, social login/SSO, Actions Taken/Service Actions, SLA/escalation/notifications, analytics beyond queue counts, production hosting changes, multiple roles per user, user deletion/bulk/import/export, departments/profile photos/account history, unlock/approval workflows. Admin list pagination, multi-column sorting and multiple simultaneous filters are not required. No new inline attachment preview.

4. Functional Requirements

ID	Requirement
FR-01	Authenticate active users by email/password and return only safe current-user data.
FR-02	Gate initial-password sessions until successful password change; support logout and session expiration.
FR-03	Display current name/role and only permitted navigation; clear protected client data on identity change or session loss.
FR-04	Enforce role and requester ownership at every protected backend operation, including direct attachment requests.
FR-05	Migrate RequesterUser into User without losing IDs, tickets, attachment history/bytes or creation-idempotency relationships.
FR-06	Continue Lab 2 create/list/detail and attachment validation/download/soft-removal behavior through authenticated Requester identity.
FR-07	Provide staff queue search, filters, deterministic sorting, pagination and assigned/unassigned information.
FR-08	Provide role-authorized staff detail and safe attachment metadata/download continuity.

ID	Requirement
FR-09	Permit IT Staff to claim, assign/reassign and clear a ticket owner, subject to active eligible-user checks and conflicts.
FR-10	Initialize IT Priority from Requested Priority; permit operational updates without changing the requested value.
FR-11	Enforce the documented eight-status transition matrix, owner preconditions and confirmations.
FR-12	Let an owning Requester append public comments and indicate apparent resolution without formally resolving/closing.
FR-13	Let IT Staff append public comments/internal notes; return notes only to IT Staff and Administrator.
FR-14	Provide Administrator user list, name/email search, optional single-role filter, create and edit.
FR-15	Support activation/deactivation and new initial passwords; enforce unique emails, one role, self-deactivation and last-admin safety.
FR-16	Deliver reusable Zen Green screens, usable desktop/tablet/mobile layouts, accessible controls and meaningful feedback.
FR-17	Provide safe validation, forbidden/not-found/conflict/failure responses without disclosing private records or credentials.
FR-18	Maintain AC-to-test traceability, migration/regression evidence, peer review, AI-use records and final-main submission evidence.

5. Business Rules

Authentication and identity

- **BR-01:** Only active users with valid credentials authenticate. Wrong passwords, unknown emails and inactive accounts share 401 `INVALID_CREDENTIALS` and the message "Unable to sign in. Check your credentials or contact your administrator." Do not reveal which condition occurred.
- **BR-02:** `mustChangePassword=true` allows only current user, CSRF retrieval, password change and logout. All other application APIs return 403 `PASSWORD_CHANGE_REQUIRED`; frontend routing alone is insufficient.
- **BR-03:** Identity comes from the server session. Ignore `X-Requester-Id` entirely; never fall back to it. Reject client-supplied identity/system fields in mutation bodies. Requester list/detail queries always constrain by the authenticated ID.
- **BR-04:** Public Comments are visible to the owning Requester, IT Staff and Administrator. Internal Notes are visible only to IT Staff and Administrator. A Requester's DTO never contains notes, note counts or note snippets.
- **BR-05:** Apparent resolution is an owning Requester's indication only; it does not change status or assign responsibility. Only IT Staff formally resolve/close in this contract.
- **BR-06:** Every user has exactly one role: `REQUESTER`, `IT_STAFF`, `ADMINISTRATOR`. No implied role hierarchy; the matrix below is authoritative.
- **BR-07:** Email is trimmed and lowercased before validation/storage/lookup, at most 254 characters, with a valid local part and domain; no provider-specific dot/plus rewriting. Database uniqueness is authoritative. Name is trimmed Unicode NFC, 1-100 characters. Lengths in this contract use Unicode code points unless stated otherwise.
- **BR-08:** Initial/new passwords contain 15-128 characters and at most 512 UTF-8 bytes, with no trimming, silent normalization, composition rules or truncation. Reject all-whitespace values; accept spaces, Unicode and pasted passphrases. Confirmation must match exactly; the new password must differ from the current password. These are project decisions, not exact handout limits.
- **BR-09:** Use asynchronous Node `crypto.scrypt`, random salt of at least 16 bytes, 64-byte derived key, `N=131072`, `r=8`, `p=1`, and `maxmem=256 MiB`; store a versioned parameter/salt/hash string. Compare equal-length derived keys using `timingSafeEqual`. Bound concurrent hashing to two jobs; do not weaken costs in production code for tests. Passwords/hash strings never enter logs, DTOs or URLs.
- **BR-10:** Use database-backed opaque sessions: 32 random bytes in a host-only `HttpOnly` cookie, only its SHA-256 digest in the database. Absolute lifetime is 8 hours (15 minutes for initial-password sessions), with no sliding renewal. Rotate token after login and successful password change. Logout revokes server state and clears cookie. All user sessions are revoked on password reset/change, role change or activation change; a successful self password change receives one new session. Re-read user state on every request.
- **BR-11:** Cookie/CORS/CSRF behavior is fixed in `api-spec.md`. No session token or password in local/session storage. On logout/401/account change, clear ticket/attachment/queue/user caches, pending creation keys and legacy `toktickit.requester` state. Never auto-replay a failed mutation after signing in.
- **BR-12:** In the single-process local lab server, enforce 5 failed logins per normalized email and 30 failed logins per client IP per fixed 15-minute window; the next attempt returns 429 and `Retry-After` until expiry. Unknown/inactive users count identically. Use a dummy password hash for credential comparisons of unknown users. Limit password-change attempts to 5 failures per session per 15 minutes. Bound and expire limiter entries; restart resets these local counters, not sessions. No permanent lock/unlock feature.

Ticket access and workflow

- **BR-13:** `requesterId` is immutable historical authorship. Ticket owner is a separate nullable `ownerId`. Eligible new owners are active IT Staff or Administrators. Admin eligibility does not grant operational permissions.
- **BR-14:** IT Staff may operate any ticket, including a ticket assigned to another eligible user. Claim succeeds only when unassigned; a competing claim returns 409 `TICKET_CONFLICT`. Reassignment and clearing ownership require explicit confirmation. Clearing an owner is permitted only in NEW, OPEN or REOPENED.
- **BR-15:** Preserve `requestedPriority`; initialize/backfill `itPriority` from it and make IT Priority non-null. IT Staff can set LOW/MEDIUM/HIGH on non-terminal tickets. Administrator can also update IT Priority as the handout expressly permits, but has no other ticket mutation rights in this project's matrix.
- **BR-16:** Each ticket has an integer `version`, initially 1. Assignment, priority, status and resolution-indication mutations require `expectedVersion` and atomically increment it plus `updatedAt`. Mismatches return 409 `TICKET_CONFLICT` without overwriting. Comment/note appends update `updatedAt` but not this operational version, so concurrent conversation does not unnecessarily block operations.
- **BR-17:** Status updates follow the matrix below. Same-status writes and unlisted transitions are invalid. An active eligible owner is required on entry into IN_PROGRESS, WAITING_FOR_REQUESTER or RESOLVED. CLOSED requires a prior RESOLVED status. Actions Taken is not a prerequisite in Lab 3.
- **BR-18:** Requester resolution indication is allowed in OPEN, IN_PROGRESS, WAITING_FOR_REQUESTER and REOPENED. Store `requesterResolvedAt` using server time. Repeating the indication at the current version returns the existing result without incrementing version; a stale version still conflicts. Reset the indication when a ticket becomes REOPENED. No separate custom status is created.
- **BR-19:** CLOSED and CANCELLED tickets are read-only for assignment, priority, resolution indication and conversation. Reopening CLOSED is the one permitted exception; CANCELLED is terminal. RESOLVED still accepts conversation, assignment and priority, but its owner cannot be cleared.
- **BR-20:** Requesters retain Lab 2 attachment upload/download/soft-removal rules on owned tickets, including historical/terminal tickets. IT Staff and Admin can read/download permitted existing attachments on any ticket, but cannot upload/remove them. Removed/unavailable bytes remain inaccessible. Existing validation, safe filenames, limits, compensation and idempotent ticket creation remain in force.
- **BR-21:** Comments and notes are separate append-only resources. Content is Unicode NFC, CRLF-to-LF normalized and trimmed, 1-2,000 characters. Reject empty/blank/over-limit values and client author/time/visibility overrides. Render escaped plain text with line breaks; no HTML/Markdown execution. Each entry has UUID, ticket ID, author ID and server creation time. No edit/delete endpoints.
- **BR-22:** Conversation lists are oldest-first by (`createdAt`, `id`) with `page/pageSize` metadata. No cross-ticket leakage. A failed post retains text, disables duplicate clicks while pending and does not automatically retry an uncertain append; reload entries before the user chooses to retry.
- **BR-23:** Queue search matches number/summary/description; filters and sorting are defined in `api-spec.md`. Role and ownership authorization applies before returning totals, lookup data, record existence or validation details. Missing and non-owned Requester resources have the same safe 404 response.

Administration and data preservation

- **BR-24:** Only Administrators list/search/create/edit users and set initial passwords. Create requires one role, active state and an initial password. Password issuance is manual in this local lab: admin enters and communicates it outside the app; the API never returns passwords. No email delivery.
- **BR-25:** Admin cannot deactivate their own account. No operation may deactivate or demote the last active Administrator. All admin create/edit/reset mutations serialize through one transaction-scoped database advisory lock, recheck actor authorization inside the transaction, check target version and invariants, then commit. Concurrent requests cannot leave zero active admins.
- **BR-26:** Prevent deactivation or role change away from IT_STAFF/ADMINISTRATOR for a user owning tickets outside CLOSED/CANCELLED (409 `USER_HAS_ACTIVE_TICKETS`). IT Staff must reassign those tickets first. Historical terminal assignments, requester authorship and comment/attachment authors remain preserved even after role/activity changes.
- **BR-27:** Admin edits use integer user `version` for optimistic concurrency. Increment it on account edit, password change or reset. Reset sets `mustChangePassword=true`, invalidates all sessions and never returns the new password/hash. Ordinary edits do not reset passwords. Admin self-demotion is allowed only when another active Admin remains and BR-26 permits it; it invalidates the current session.
- **BR-28:** Migration preserves IDs, existing email/name/timestamps, tickets, categories, systems, attachment metadata/bytes and idempotency records. Preflight normalized-email collisions; stop with an actionable non-secret report instead of merging/deleting users. No development-database reset.

- **BR-29:** Seed is local/test-only and idempotent: at least 4 active + 1 inactive Requesters, 3 active + 1 inactive IT Staff, and 1 active Admin. Use deterministic seed IDs, varied queue statuses/priorities/ownership and harmless conversation examples. Reruns do not reset existing passwords, reactivate users or overwrite user edits/tickets.
- **BR-30:** Automated migration/regression tests run only in an isolated guarded test database and upload directory. Test evidence reports actual commands, branch/commit, counts and results; pending or blocked checks never become Pass.

Authorization matrix

All permissions require an active, non-expired, password-changed session, except the four restricted authentication operations. Own means `ticket.requesterId == session.userId`.

Operation	Requester	IT Staff	Administrator
Current user, CSRF, logout, password change	Yes, including restricted session	Same	Same
Active category/system references	Yes	Yes	Yes
Create ticket / My Tickets	Own	No	No
Requester detail	Own	No	No
Shared queue / staff detail	No	Yes	Read-only
Eligible owner lookup	No	Yes	No
Claim / assign / clear owner	No	Yes	No
Update IT Priority	No	Yes	Yes
Change status	No	Yes	No
Indicate apparent resolution	Own	No	No
Read Public Comments	Own	Any ticket	Any ticket
Append Public Comments	Own, non-terminal	Any non-terminal	No
Read Internal Notes	No	Any ticket	Any ticket
Append Internal Notes	No	Any non-terminal	No
Attachment metadata/download	Own	Any ticket	Any ticket
Attachment upload/soft-remove	Own, Lab 2 rules	No	No
User list/create/edit/reset	No	No	Yes

Admin's landing page remains User Management. A secondary Ticket Lookup route exposes the narrow read/priority rights required by the handout; it does not show IT Staff claim/status/post actions. This resolves the handout's conceptual role separation and explicit Admin note/priority/owner permissions without granting all staff powers.

Status transition matrix

Only IT Staff can execute the following. Values use API enum spelling; UI displays title-case labels. All require `expectedVersion`.

From	Permitted next statuses
NEW	OPEN, CANCELLED
OPEN	IN_PROGRESS, WAITING_FOR_REQUESTER, CANCELLED
IN_PROGRESS	WAITING_FOR_REQUESTER, RESOLVED, CANCELLED
WAITING_FOR_REQUESTER	IN_PROGRESS, RESOLVED, CANCELLED
RESOLVED	CLOSED, REOPENED
CLOSED	REOPENED
REOPENED	OPEN, IN_PROGRESS, WAITING_FOR_REQUESTER, CANCELLED
CANCELLED	None

Targets RESOLVED, CLOSED, REOPENED and CANCELLED require a confirmation dialog and `confirmed=true`; there is no required resolution-summary/Actions Taken field. Claim and assignment do not automatically change status. All nonlisted role/state combinations are denied.

6. UI Summary

The complete screen contract, dimensions, components, states and visual checklist are in [ui-spec.md](#). The user explicitly requested polished UI that matches the assignment. Visual consistency and usable states are acceptance requirements. Avoid reproducing excluded screenshot controls such as reset-email, Service Actions or unnecessary admin pagination.

7. Data Model and Migration

Model	Required increment
User	Evolve/rename RequesterUser, preserving UUIDs and timestamps; normalized unique email, name, role, isActive, passwordHash, mustChangePassword, version=1. Existing users default REQUESTER.
AuthSession	UUID, unique tokenHash, userId FK, csrfToken (32 random bytes encoded), createdAt, expiresAt. No raw session token. Index userId and expiresAt; FK restricts user deletion.
Ticket	Preserve fields/FKs and creation records; add nullable ownerId -> User, version=1, nullable requesterResolvedAt; make itPriority required after backfill; expand TicketStatus enum.
PublicComment / InternalNote	Separate models with UUID, ticketId, authorId, content, createdAt; index (ticketId, createdAt, id); restrictive FKs.
Attachment / TicketCreateRequest	Retarget User relations while preserving original IDs and physical columns, including uploadedByRequesterId/removedByRequesterId; legacy names remain internal history.

Queue indexes: retain Lab 2 requester indexes; add (currentStatus, updatedAt), (ownerId, updatedAt) and (itPriority, updatedAt). User email unique index is authoritative; no broad text-search infrastructure needed for the lab dataset.

Migration sequence: (1) back up development database/private files and record row counts/relationships; (2) preflight normalized emails; (3) rename table and preserve FKs, add schema fields/models/enums; (4) backfill normalized email, REQUESTER, versions, IT Priority; (5) run an idempotent initialization script for users with missing hashes, consuming an ignored local JSON map of user ID to initial password; validate every target/password and hash before a transaction, set mustChangePassword, never print passwords; (6) verify no missing hashes, apply NOT NULL and unique constraints; (7) run safe seed, reconcile counts/IDs/attachment checksums and ownership. An interrupted run safely resumes; no login is served during the maintenance migration. The input map is deleted by its owner after secure local distribution. Test fixtures use synthetic credentials only.

Existing seed/test consumers are updated to User explicitly. Lab 2 tests of selector/header semantics are replaced with authentication tests; the behavior they previously protected is retained in migrated regression tests. Legacy GET /api/requesters is removed (404); legacy UI /select-requester redirects to login without returning the user directory.

8. API Contract

Foundation implementation refinement for peer review: the migration sequence in section 7 now enforces a non-null passwordHash immediately, using a non-verifiable !INITIAL_PASSWORD_REQUIRED marker until the same private-map initializer completes. No default credential is embedded in the migration; maintenance continues until all markers are replaced. AuthSession also stores userVersion to invalidate stale sessions on account changes. Rationale, actual regression coverage and remaining rollout checks are in [foundation.md](#). This refines the intermediate schema mechanics without relaxing credential initialization or data-preservation requirements.

See [api-spec.md](#) for exact routes, body/response shapes, cookies, CSRF, limits, query handling and safe errors. Lab 2 APIs retain their resource shapes except explicit authenticated identity, non-null IT Priority and additive workflow fields.

9. Acceptance Criteria

ID	Observable acceptance criterion
AC-01	Active valid login sets the session cookie and safe role/user response; unknown, wrong-password and inactive attempts have indistinguishable 401 bodies.
AC-02	Initial-password login permits only auth operations; direct application API access fails until valid change rotates the session and permits the role landing page.
AC-03	Password boundary/confirmation/current-password checks and failed-attempt limits reject invalid inputs safely without plaintext storage or logs.

ID	Observable acceptance criterion
AC-04	Logout, expiry, reset, role/activity changes invalidate old sessions; refresh/back navigation displays no cached protected data; CSRF/origin violations fail.
AC-05	Every role/operation in the authorization matrix is exercised directly; forged requester IDs never change identity and ownership failures do not disclose existence.
AC-06	Migration preserves Ticket/Attachment/CreateRequest IDs, authorship, bytes and relationships, backfills priority and initializes mandatory-change credentials; collisions stop migration safely.
AC-07	Repeated seed runs preserve edits/passwords and satisfy minimum active/inactive roles plus realistic tickets/conversation.
AC-08	Authenticated Requester creates tickets with the existing validation/idempotency behavior, searches only own records and sees no selector or client-derived identity.
AC-09	Owned attachment upload/download/soft-removal, limits, unavailable/removed states and compensation continue; staff/admin get safe read access only.
AC-10	Queue returns the documented search/filter/rank/sort/page subset and metadata; invalid queries fail; empty and no-results differ.
AC-11	Staff detail presents complete historical data, active/removed attachment states and permitted controls; Admin detail exposes only read and IT Priority rights.
AC-12	Claim/reassignment/clear-owner enforce eligible accounts/state/version; concurrent claim produces one winner and one safe conflict.
AC-13	New/migrated IT Priority equals Requested Priority initially; only Staff/Admin can change IT Priority and the requested value remains unchanged.
AC-14	Every allowed and disallowed status edge, owner precondition, same-state rejection, terminal rule and confirmation is tested; stale updates never overwrite.
AC-15	Owning Requester indicates apparent resolution only in allowed states; status is unchanged, duplicates do not duplicate state, and reopen clears the indication.
AC-16	Public Comments validate and append with server author/time, deterministic pagination and safe plain-text rendering; non-owner and terminal writes fail.
AC-17	Internal Notes never appear in Requester payloads/counts/navigation; direct reads/writes are denied; Staff can append and Admin can read only.
AC-18	Admin list/search/role filter and create/edit work with exactly one valid role, normalized unique email and documented field errors.
AC-19	Admin initial-password reset invalidates sessions and requires change at next login without sending/returning email or plaintext secrets.
AC-20	Self-deactivation, removing last active Admin, assigned-user deactivation/demotion and stale edits are blocked, including concurrent requests.
AC-21	Login, password change, Requester detail, queue, staff detail and admin screens provide busy/validation/success/empty/no-results/forbidden/not-found/conflict/safe-failure feedback where meaningful.
AC-22	Major screens pass desktop/tablet/mobile visual review with consistent tokens, readable hierarchy, distinct notes/comments and no clipping/overlap/page overflow.
AC-23	Keyboard navigation, labels, error focus/announcements, dialog focus restoration, touch targets and non-color status communication work.
AC-24	Unit/API/UI/regression/E2E results, screenshots, review history and AC mappings are captured honestly from final main and linked in the nine-part submission.

Each AC maps to planned tests in [tests.md](#); planned filenames are not yet evidence of implemented tests.

10. Definition of Done

- [] Reviewed contract is internally consistent; all FR/BR/AC items are implemented or explicitly revised with rationale and peer review.
- [] Migration preserves development data and is demonstrated on isolated existing-Lab-2 fixtures; seed is repeatable without resetting accounts.
- [] Authentication, direct API authorization, requester regression, staff operations and minimal administration meet this contract.
- [] All planned relevant tests pass with no required skipped/disabled tests; failures are fixed rather than hidden by weakening assertions.
- [] Both production builds and final-main unit/API/UI/regression/E2E checks pass; commands/commit/results are recorded.

- [] Desktop/tablet/mobile screenshots and completed human visual checklist demonstrate the requested UI quality and accessibility.
- [] README setup/migration/initial-password distribution/test/build instructions and .gitignore are correct; no secrets/local uploads/generated noise in Git.
- [] Six Issues use the existing Backlog -> Specified -> Started -> PR Review -> Fixing -> Done workflow as appropriate; each PR has its formal Development-panel issue link.
- [] Feature PRs 1-5 target lab3-staging; approving peer reviewer merges after a real review. Issue 6 uses the release PR from lab3-staging to main, avoiding a seventh planned review round.
- [] reviewer.md records real reviewed commits, feedback, responses, approvals and merges. Do not invent approval or send review requests without the user's authorization.
- [] ai-use.md grows to 6-10 real selected prompts and a student-authored reflection. Initial log is intentionally incomplete.
- [] Submission is one concise PDF, Answer Part 1 through Answer Part 9 in order, working links/readable screenshots; final main is authoritative.

11. Decisions and Review Boundaries

This draft chooses session cookies over client-stored bearer tokens for straightforward revocation and current-role checks in the existing Express/PostgreSQL app. Scrypt is available in the existing Node runtime; its parameters follow the fallback guidance in the [OWASP password storage cheat sheet](#) and the [Node crypto API](#). Cookie/session and CSRF decisions use the [OWASP session guidance](#) and [CSRF guidance](#), consulted 2026-09-08. These references inform implementation decisions; they do not add excluded identity-management features.

Before implementation, peer review should specifically check Admin's narrow ticket permissions, status transitions/owner requirements, terminal conversation versus attachment behavior, 15-character passphrases, session revocation, initial-password migration and assigned-user deactivation rules. These are explicit project decisions rather than unstated assumptions.

The six-work-item dependency plan and submission mapping are in [issue-plan.md](#). Runtime feature implementation begins after the engineering contract's review; this draft is a reviewable work product, not a completed application.

Companion [API contract](#).

Answer Part 3

Test plan and final-main execution

All runs used application main `b3a65949f3fad3c84ffabbe01707db0d929686f0`, isolated test databases and sequential execution. Unit/API database: `lab3_final_20260927_unit_test`. Browser database: `lab3_final_20260927_browser_test`. Full command timestamps, exit codes and starting source status are in [results.json](#).

Check	Actual result on main	Full output
Unit / API / UI / regression	389 passed in 36 files; zero skipped; 94.38 seconds	unit.log
Browser journeys	17 passed; zero skipped; 1.5 minutes	browser.log
Server build	Passed; exit 0	server-build.log
Client build	Passed; exit 0	client-build.log

[Corrected fresh-database runbook](#): generate Prisma, temporarily point DATABASE_URL at the guarded test database, run `prisma migrate deploy`, restore the original environment, and only then run `npm test`. Browser global setup applies its own migrations/seeds to the separate guarded target. [Actual migration output](#) confirms all three committed migrations were applied. Docker/memory preparation interruptions are recorded separately and are not counted as application test failures or passes.

Rendered current test-first plan, complete scenario/file matrix and ownership mapping; repeated staging execution history omitted. [Source document](#).

Test plan and traceability

Current execution results below supersede historical staging counts. The rendered plan includes its original scenarios and actual file mapping; earlier duplicate execution histories remain available in the linked source.

1. Test-first workflow and environment

Each feature Issue selects mapped FR/BR/AC/Test IDs, writes tests that fail for the intended missing behavior, records a concise red result, implements, then refactors with green tests. Plan tests before or alongside implementation, not after reading generated tests. Changes to requirements and planned assertions are reviewed together; no weakening authorization or migration tests to manufacture green results.

Use existing Vitest, Supertest, React Testing Library and Playwright. Database tests use the existing TEST_DATABASE_URL guard and a dedicated test database distinct from development. Migration fixtures use a separate temporary guarded database/schema with Lab 2 data and isolated upload storage; never reset development. Test setup/teardown must reject unsafe URLs/paths before destructive operations. Hash tests use real configured costs in focused cases; unrelated UI tests may mock HTTP. API/security tests must not bypass authentication/authorization middleware.

2. Planned tests

Every row initially has Final = Planned. Multiple test cases within a row cover its full expected-result statement, not just one happy path.

Test ID	Type	AC	What it tests / expected result	Actual automated file(s)	Current evidence
UNIT-01	Unit	AC-03	Email/name normalization, 15/128 code-point and 512-byte password boundaries, no truncation, confirmation, whitespace and real salted script verification; wrong passwords fail.	server/tests/lab-03/auth.unit.test.ts	Implemented; see integrated execution/scope
UNIT-02	Unit	AC-03, AC-04	Fixed-window limits and expiry with controlled clock, safe dummy-hash path, random session/digest generation and restricted/full expiry.	server/tests/lab-03/auth.unit.test.ts	Implemented; see integrated execution/scope
UNIT-03	Unit/API	AC-10	Strict queue keys/types/duplicates, rank ordering, pagination and deterministic tie-break parsing.	server/tests/lab-03/staff-workflow.api.test.ts + server/tests/lab-02/ticket-query.unit.test.ts	Implemented; see integrated execution/scope
UNIT-04	API	AC-12, AC-14, AC-15	Enumerate all eight-by-eight status pairs, owner/terminal/confirmation preconditions and requester indication states.	server/tests/lab-03/staff-workflow.api.test.ts	Implemented; see integrated execution/scope
UNIT-05	API	AC-16, AC-17, AC-18	Comment normalization/length and admin fields/one-role validation including Unicode and unknown properties.	server/tests/lab-03/staff-workflow.api.test.ts + server/tests/lab-03/admin-users.api.test.ts	Implemented; see integrated execution/scope
API-01	API	AC-01, AC-03	Active valid login; unknown/wrong/inactive same safe 401; normalized email; invalid body and failed-attempt 429/Retry-After.	server/tests/lab-03/auth.api.test.ts	Implemented; see integrated execution/scope
API-02	API	AC-02, AC-03	Initial-password gate on every protected endpoint; correct change, wrong current password, mismatch, same-password and exact boundaries; token rotation.	server/tests/lab-03/auth.api.test.ts	Implemented; see integrated execution/scope
API-03	API	AC-04	me/logout/idempotent logout/expiration and old-cookie rejection after change/reset/role/activity changes; cookie flags, no-store, no secrets.	server/tests/lab-03/auth.api.test.ts	Implemented; see integrated execution/scope
API-04	Security/ API	AC-04, AC-05	Pre-auth and session CSRF, missing/wrong token/Origin, credentialed CORS allowlist, hostile Origin and legacy header-only attempts.	server/tests/lab-03/authorization.api.test.ts	Implemented; see integrated execution/scope
API-05	Security/ API	AC-05, AC-09, AC-17	Table-driven full role/operation matrix incl. Admin's limited detail/priority rights; owned/non-owned/missing ticket/file; response/private-count leakage; requester header/body spoof.	server/tests/lab-03/authorization.api.test.ts	Implemented; see integrated execution/scope
API-06	API	AC-10	Search each field, AND filters, each owner mode, priority ranks both ways, each sort/ties, pages/totals/out-of-range, invalid/unknown/repeated params.	server/tests/lab-03/staff-workflow.api.test.ts	Implemented; see integrated execution/scope
API-07	API	AC-11, AC-12	Safe detail/eligible owners, claim and reassign/clear; reject inactive/wrong-role targets and terminal/clear-state violations; preserve requester identity.	server/tests/lab-03/staff-workflow.api.test.ts	Implemented; see integrated execution/scope
API-08	Concurrence/ API	AC-12, AC-13, AC-14	Two independent requests claim/update same version: one succeeds, loser 409, no overwrite/500; owner deactivate versus assign/start/resolve uses shared lock.	server/tests/lab-03/staff-workflow.api.test.ts	Implemented; see integrated execution/scope

Test ID	Type	AC	What it tests / expected result	Actual automated file(s)	Current evidence
API-09	API	AC-13, AC-14	Priority changes by Staff/Admin only; requested priority unchanged; every status edge, confirmation and active-owner prerequisite enforced by real API.	server/tests/lab-03/staff-workflow.api.test.ts	Implemented; see integrated execution/scope
API-10	API	AC-15	Owned indication, permitted/disallowed states, no status change, repeat/current versus stale version, reopen clearing and non-owner denial.	server/tests/lab-03/staff-workflow.api.test.ts	Implemented; see integrated execution/scope
API-11	API	AC-16, AC-17	Append/list public and internal entries, author/time from server, Unicode/blank/length/HTML-as-text, deterministic pages, terminal writes, absent edit/delete and no Requester note leakage.	server/tests/lab-03/staff-workflow.api.test.ts	Implemented; see integrated execution/scope
API-12	API	AC-18	Admin list name/email search, role filter/no-results, create and complete edit, email normalization, duplicate/invalid email/role/types and concurrent duplicate creation.	server/tests/lab-03/admin-users.api.test.ts	Implemented; see integrated execution/scope
API-13	API	AC-19	Initial-password issuance/reset including self-reset, force change, immediate old-session invalidation and no password/hash in response/log.	server/tests/lab-03/admin-users.api.test.ts	Implemented; see integrated execution/scope
API-14	Concurrency/API	AC-20	Self-deactivation/last-admin/stale-edit protection; simultaneous demotions/deactivations still leave one active Admin; assigned-user deactivation/demotion conflicts; actor rechecked after lock.	server/tests/lab-03/admin-users.api.test.ts	Implemented; see integrated execution/scope
API-15	Failure/API	AC-21	Inject auth/queue/detail/conversation/admin database failures; safe 500/correlation and no sensitive output; transactional updates roll back.	server/tests/lab-03/safe-errors.api.test.ts	Implemented; see integrated execution/scope
MIG-01	Migration/integration	AC-06	Apply staged migration to populated Lab 2 fixture; compare IDs/counts/FKs/create-request hashes/attachment metadata and byte checksums; backfill priority and mandatory-change credentials.	server/tests/lab-03/migration.integration.test.ts	Implemented; see integrated execution/scope
MIG-02	Migration/integration	AC-06	Normalized email collisions/missing credential map fail without data loss; interrupted initializer resumes; final non-null constraints hold.	server/tests/lab-03/migration.integration.test.ts	Implemented; see integrated execution/scope
MIG-03	Seed/integration	AC-07	Seed twice, edit password/account/ticket between runs; preserve edits and relationships, satisfy active/inactive role counts and meaningful queue/conversation distribution.	server/tests/lab-03/migration.integration.test.ts	Implemented; see integrated execution/scope
REG-01	Regression/API	AC-05, AC-08	Rework Lab 2 create/list/detail tests to authenticated agents: ownership, validation, concurrent idempotency, filters and historical references preserved.	server/tests/lab-02/create-ticket.api.test.ts + server/tests/lab-02/my-tickets.api.test.ts + server/tests/lab-02/ticket-detail.api.test.ts	Implemented; see integrated execution/scope
REG-02	Regression/API	AC-09	Authenticated attachment MIME/signature/filename/size/count/concurrent-upload/compensation/removal/unavailable lifecycle; exact file hashes, Staff/Admin read-only access, authorization before storage.	server/tests/lab-02/attachments.api.test.ts	Implemented; see integrated execution/scope
UI-01	UI	AC-01, AC-03, AC-21, AC-23	Login fields/show password/validation/busy/generic invalid and inactive feedback/rate limit/failure; submit focus and labels.	client/tests/lab-03/Login.test.tsx	Implemented; see integrated execution/scope
UI-02	UI	AC-02, AC-03, AC-21, AC-23	Mandatory-change guard, rules/confirmation/current-password error, busy/success/failure, no bypass and permitted ordinary back navigation.	client/tests/lab-03/ChangePassword.test.tsx	Implemented; see integrated execution/scope

Test ID	Type	AC	What it tests / expected result	Actual automated file(s)	Current evidence
UI-03	UI	AC-04, AC-05, AC-08	Session bootstrap/expiry/logout failure/success, role links, validated return path and cache clearing; remove legacy selector/storage and never replay mutation after login.	client/tests/lab-03/ApplicationShell.test.tsx	Implemented; see integrated execution/scope
UI-04	UI	AC-10, AC-21, AC-23	Queue controls, pagination/reset, loading/empty/no-results/failure, matching-query retained data, explicit detail link and keyboard usability.	client/tests/lab-03/StaffWorkflow.test.tsx	Implemented; see integrated execution/scope
UI-05	UI	AC-11, AC-12, AC-13, AC-14, AC-21	Detail fields, owner/priority/status controls, confirmations, Admin restriction, active/removed/unavailable files, read-only/forbidden/not-found/failure/conflict.	client/tests/lab-03/StaffWorkflow.test.tsx + client/tests/lab-03/ConversationRecovery.test.tsx	Implemented; see integrated execution/scope
UI-06	UI	AC-16, AC-17, AC-21, AC-23	Separate drafts/private notice, escaping malicious content, post busy/failure/uncertain retry, history pagination and keyboard tabs; no Admin composer.	client/tests/lab-03/StaffWorkflow.test.tsx + client/tests/lab-03/ConversationRecovery.test.tsx	Implemented; see integrated execution/scope
UI-07	UI	AC-08, AC-09, AC-15, AC-17	Requester detail/public comments/indication state and unchanged actual status, attachment continuity; no internal-note controls/data.	client/tests/lab-02/RequesterTicketDetail.test.tsx + client/tests/lab-03/StaffWorkflow.test.tsx	Implemented; see integrated execution/scope
UI-08	UI	AC-18, AC-19, AC-20, AC-21, AC-23	Admin list/search/filter/create/edit/reset, password clearing, inline safety/duplicate/conflict errors, own session invalidation, dialog focus/discard behavior.	client/tests/lab-03/UserManagement.test.tsx	Implemented; see integrated execution/scope
STYLE-01	UI style	AC-22, AC-23	Shared Zen Green tokens, primary/readonly/badge/error/focus conventions, private composer separation and absence of excluded controls.	client/tests/lab-02/ZenGreenStyles.test.tsx + e2e/lab-03/system-verification.spec.ts	Implemented; see integrated execution/scope
RESP-01	Responsive	AC-22, AC-23	Table/card/panel stacking and long labels/filenames/descriptions at 1440/834/390 and 320 widths; no page overflow and usable actions.	e2e/lab-03/system-verification.spec.ts + e2e/lab-03/staff-ticket-flow.spec.ts + e2e/lab-03/admin-users.spec.ts	Implemented; see integrated execution/scope
E2E-01	E2E	AC-01, AC-02, AC-03, AC-04, AC-05	Real login/invalid/inactive/first-change/logout; old-cookie API access rejected; all role landing pages and restricted links.	e2e/lab-02/authentication.spec.ts + e2e/lab-03/system-verification.spec.ts	Implemented; see integrated execution/scope
E2E-02	E2E	AC-08, AC-09, AC-10, AC-11, AC-12, AC-13, AC-14, AC-15, AC-16, AC-17	Requester creates with attachment; Staff searches/claims/changes priority/status/posts public/private; Requester sees public only and indicates resolution; Staff resolves/closes/reopens.	e2e/lab-03/staff-ticket-flow.spec.ts	Implemented; see integrated execution/scope
E2E-03	E2E	AC-04, AC-18, AC-19, AC-20	Admin creates/edits/resets user; user forced to change; duplicate/self/last-admin/assigned-owner guards; non-Admin denial.	e2e/lab-03/admin-users.spec.ts	Implemented; see integrated execution/scope
VIS-01	Visual/manual + capture	AC-21, AC-22, AC-23	Capture all ui-spec scenes at three viewports and inspect hierarchy/privacy/states/focus/clipping/overlap; record per-scene result and correction.	e2e/lab-03/system-verification.spec.ts + e2e/lab-03/staff-ticket-flow.spec.ts + e2e/lab-03/admin-users.spec.ts + docs/lab-03/ui-spec.md	109 captures; agent inspection recorded; final human approval pending
REL-01	Release/manual	AC-24	Run full guarded suite/builds on final main; map real outputs/screenshots/PRs/commit and nine PDF parts; check links and all Issues Done only on completion.	docs/lab-03/tests.md + docs/lab-03/reviewer.md	Planned

3. Feature ownership and regression policy

Work item 2 owns UNIT-01/02, API-01..05 for its implemented endpoints, MIG-01..03, REG-01/02 and UI-01..03. Work item 3 owns UNIT-03..05 (conversation portion), API-06..11, UI-04..07. Work item 4 owns admin UNIT-05, API-12..14 and UI-08. Each feature extends API-02/04/05 with its newly introduced protected endpoints and implements its API-15 failure cases, style and responsive checks. AC-05's complete role/operation matrix is only marked Pass once all endpoint increments are integrated; the foundation PR records its narrower implemented coverage explicitly. Work item 5 completes cross-feature E2E/visual checks, not a delayed first pass at feature tests. Work item 6 owns REL-01.

Old Lab 2 selector/header-specific assertions become obsolete and are replaced explicitly. Preserve all still-relevant tests and update their login setup/expected initial IT Priority deliberately; document replacements so deleted selector tests cannot hide lost requester/attachment protection. Existing Lab 1 category/system UI assumptions may need authenticated setup; health remains public. Unchanged tests must keep running.

Complete final-main passing command output

Console styling and redundant blank lines are normalized for readability. The linked text logs retain the full original output. These are new main runs, not copied staging summaries.

unit.log

```
> toktickit-monorepo@1.0.0 test
> vitest run
RUN v3.2.7 C:/Users/User/toktickit/tmp/lab3-final-main
✓ server/tests/lab-02/attachments.api.test.ts (9 tests) 3803ms
  ✓ Attachment lifecycle > uploads verified bytes, returns safe metadata, downloads, and retains soft-removal metadata 499ms
✓ server/tests/lab-03/staff-workflow.api.test.ts (127 tests) 3823ms
✓ server/tests/lab-03/admin-users.api.test.ts (25 tests) 3092ms
  ✓ API-12-14 administrator accounts > normalizes new users, stores a real hash and handles simultaneous duplicate emails
542ms
  ✓ API-12-14 administrator accounts > resets a password, invalidates every session, requires a different password and
enforces the initial gate 1378ms
  ✓ server/tests/lab-02/my-tickets.api.test.ts (19 tests) 573ms
  ✓ server/tests/lab-02/create-ticket.api.test.ts (14 tests) 550ms
  ✓ server/tests/lab-03/migration.integration.test.ts (3 tests) 12327ms
  ✓ Lab 2 to Lab 3 data migration > preserves historical identities and attachment/idempotency relations and initializes
passwords resumably 3703ms
  ✓ Lab 2 to Lab 3 data migration > stops on normalized-email collisions without renaming or merging accounts 2746ms
  ✓ Lab 2 to Lab 3 data migration > seeds all roles and varied tickets, preserving edits, inactive accounts and changed
passwords on repeat 5876ms
  ✓ server/tests/lab-03/auth.api.test.ts (7 tests) 3669ms
  ✓ Authentication API (API-01..04) > gates initial-password sessions, changes password, rotates session and logs out 796ms
  ✓ Authentication API (API-01..04) > does not disclose unknown, inactive or wrong-password accounts 514ms
  ✓ Authentication API (API-01..04) > invalidates expired sessions and sessions whose user version or activity changes 758ms
  ✓ Authentication API (API-01..04) > limits failed login attempts and supplies a retry interval 1282ms
  ✓ server/tests/lab-03/auth.unit.test.ts (8 tests) 1565ms
  ✓ Lab 3 password rules (UNIT-01 / AC-03) > uses independent salts and real scrypt, without trimming passwords or accepting
damaged hashes 1102ms
  ✓ Lab 3 password rules (UNIT-01 / AC-03) > does not normalize distinct Unicode passwords into the same password 458ms
  ✓ server/tests/lab-03/safe-errors.api.test.ts (6 tests) 213ms
  ✓ server/tests/lab-03/authorization.api.test.ts (8 tests) 312ms
  ✓ server/tests/lab-02/ticket-detail.api.test.ts (2 tests) 265ms
  ✓ server/tests/lab-02/reference-data.api.test.ts (5 tests) 39ms
  ✓ server/tests/lab-02/attachment-validation.unit.test.ts (17 tests) 6ms
  ✓ server/tests/lab-02/reference-data.integration.test.ts (3 tests) 220ms
  ✓ server/tests/lab-02/ticket-query.unit.test.ts (16 tests) 11ms
  ✓ server/tests/lab-02/ticket-validation.unit.test.ts (14 tests) 4ms
  ✓ client/tests/lab-02/ResponsiveStyles.test.tsx (6 tests) 3ms
  ✓ server/tests/lab-02/test-database-guard.test.ts (6 tests) 4ms
  ✓ server/tests/lab-02/ticket-idempotency.unit.test.ts (3 tests) 3ms
  ✓ server/tests/lab-02/requester-context.api.test.ts (6 tests) 34ms
  ✓ server/tests/lab-02/ticket-number.unit.test.ts (3 tests) 4ms
  ✓ client/tests/lab-02/ZenGreenStyles.test.tsx (5 tests) 3ms
  ✓ server/tests/lab-01/categories.test.ts (1 test) 141ms
  ✓ server/tests/lab-01/server.test.ts (1 test) 16ms
  ✓ server/tests/lab-01/health.test.ts (1 test) 15ms
  ✓ client/tests/lab-02/CreateTicket.test.tsx (8 tests) 729ms
  ✓ client/tests/lab-02/RequesterTicketDetail.test.tsx (11 tests) 532ms
  ✓ client/tests/lab-02/MyTickets.test.tsx (6 tests) 434ms
  ✓ client/tests/lab-03/StaffWorkflow.test.tsx (11 tests) 561ms
  ✓ client/tests/lab-03/UserManagement.test.tsx (6 tests) 562ms
  ✓ client/tests/lab-03/ReviewRegressions.test.tsx (9 tests) 357ms
  ✓ client/tests/lab-03/ApplicationShell.test.tsx (11 tests) 327ms
  ✓ client/tests/lab-03/ConversationRecovery.test.tsx (3 tests) 422ms
  ✓ client/tests/lab-03/AdminNavigation.test.tsx (5 tests) 725ms
  ✓ client/tests/lab-03/Login.test.tsx (3 tests) 255ms
```

```
✓ client/tests/lab-03/ChangePassword.test.tsx (1 test) 129ms
Test Files 36 passed (36)
Tests 389 passed (389)
Start at 19:14:40
Duration 94.38s (transform 690ms, setup 0ms, collect 18.75s, tests 35.73s, environment 31.47s, prepare 3.44s)
```

browser.log

```
> toktickit-monorepo@1.0.0 test:e2e:capture:lab3
> node e2e/lab-03/capture-evidence.mjs
Prisma schema loaded from server\prisma\schema.prisma
Datasource "db": PostgreSQL database "lab3_final_20260927_browser_test", schema "public" at "127.0.0.1:55433"
3 migrations found in prisma/migrations
Applying migration `20260810155801_init`
Applying migration `20260831003000_lab2_data_requester_context`
Applying migration `20260913060000_lab3_accounts`
The following migration(s) have been applied:
migrations/
├─ 20260810155801_init/
│   └─ migration.sql
├─ 20260831003000_lab2_data_requester_context/
│   └─ migration.sql
└─ 20260913060000_lab3_accounts/
    └─ migration.sql
All migrations have been successfully applied.
Running 17 tests using 1 worker
(node:4000) Warning: The 'NO_COLOR' env is ignored due to the 'FORCE_COLOR' env being set.
(Use `node --trace-warnings ...` to show where the warning was created)
ok 1 e2e\lab-02\authentication.spec.ts:5:5 › AUTH-E2E initial-password gate, change, role landing and logout on a real browser (6.7s)
ok 2 e2e\lab-02\requester-ticket-flow.spec.ts:14:5 › E2E-01 creates a Ticket, finds it in My Tickets, and opens owned detail (1.5s)
ok 3 e2e\lab-02\requester-ticket-flow.spec.ts:44:5 › E2E-02 switches requester and protects direct Ticket and Attachment access (2.3s)
ok 4 e2e\lab-02\requester-ticket-flow.spec.ts:78:5 › E2E-03 exercises invalid, limit, download, and soft-removal Attachment states (1.9s)
ok 5 e2e\lab-02\responsive-visual.spec.ts:25:7 › RESP-01 keeps every requester screen usable at desktop (1.8s)
ok 6 e2e\lab-02\responsive-visual.spec.ts:25:7 › RESP-01 keeps every requester screen usable at tablet (1.7s)
ok 7 e2e\lab-02\responsive-visual.spec.ts:25:7 › RESP-01 keeps every requester screen usable at mobile (1.5s)
ok 8 e2e\lab-02\responsive-visual.spec.ts:66:5 › VIS-01 captures the complete Zen Green screenshot contract (6.3s)
ok 9 e2e\lab-03\admin-users.spec.ts:8:5 › E2E-03 Admin creates, edits and resets an account; new credentials require password change (4.1s)
ok 10 e2e\lab-03\admin-users.spec.ts:26:5 › RESP/VIS administrator directory, editor and reset dialog at four widths (3.1s)
ok 11 e2e\lab-03\admin-users.spec.ts:43:5 › Admin dirty edits survive cancelled shell navigation and browser Back (1.2s)
ok 12 e2e\lab-03\staff-ticket-flow.spec.ts:11:5 › E2E-02 staff workflow, public/private conversation, indication, Admin restriction and reopening (4.3s)
ok 13 e2e\lab-03\staff-ticket-flow.spec.ts:45:5 › RESP/VIS staff queue and private detail remain usable at desktop, tablet, mobile and 320px (3.1s)
ok 14 e2e\lab-03\system-verification.spec.ts:14:7 › SYSTEM responsive authentication, recovery and role evidence: desktop (8.9s)
ok 15 e2e\lab-03\system-verification.spec.ts:14:7 › SYSTEM responsive authentication, recovery and role evidence: tablet (10.0s)
ok 16 e2e\lab-03\system-verification.spec.ts:14:7 › SYSTEM responsive authentication, recovery and role evidence: mobile (8.2s)
ok 17 e2e\lab-03\system-verification.spec.ts:14:7 › SYSTEM responsive authentication, recovery and role evidence: narrow (7.9s)
17 passed (1.5m)
Captured 109 Lab 3 screenshots with SHA-256 manifest.
```

server-build.log

```
> toktickit-monorepo@1.0.0 build:server
> npm --prefix server run build
> toktickit-server@1.0.0 build
> tsc
```

client-build.log

```
> toktickit-monorepo@1.0.0 build:client
> npm --prefix client run build
> toktickit-client@1.0.0 build
> tsc && vite build
vite v6.4.3 building for production...
transforming...
✓ 45 modules transformed.
rendering chunks...
computing gzip size...
```

```
dist/index.html          0.48 kB | gzip: 0.32 kB
dist/assets/bootstrap-icons-mSm7cUeB.woff2 134.04 kB
dist/assets/bootstrap-icons-BeopsB42.woff  180.29 kB
dist/assets/index-CthLjcBJ.css             339.55 kB | gzip: 51.69 kB
dist/assets/index-Cmi7y-q6.js              231.77 kB | gzip: 69.49 kB
✓ built in 1.02s
```

Answer Part 4

AI use and Reflection

The Reflection below is an explicitly identified AI draft based on actual project events. Student reading/adaptation remains pending; no personal understanding or manual testing is inferred.

Rendered tool identity, all nine selected real prompts, and Reflection draft; repeated implementation diary omitted. [Source document](#).

AI use and Reflection

Tool and role

OpenAI Codex desktop agent, GPT-6 (session-provided model identity; exact service variant not independently recorded). Used for reading the Lab 3 PDF, explaining scope in Thai, inspecting the Lab 2 architecture, planning Issues, drafting the contract, implementing and testing features, addressing actual peer findings and preparing verification evidence. Independent approval belongs to the reviewer; see reviewer.md.

The handout is source material distinct from the user's request. User chose to begin the six-Issue plan and explicitly emphasized polished UI consistent with the assignment. The agent isolated work from existing uncommitted Lab 2 report edits and based the new contract on completed remote main.

Selected real prompt log

No.	User request (original Thai)	Use / result so far
1	lab 3 มาแล้วอธิบาย แล้วก็วางแผนที	Read 18-page handout and inspected mockups; explained scope/rules/deliverables and compared with existing Requester model/header context.
2	แล้วควรมีที่ Issue	Proposed a dependency-aware 10-Issue decomposition; treated count as a proposal, not a handout requirement.
3	สามารถลดได้เหมือน เพราะต้องมารอเพื่อน Approve อีก	Consolidated to six Issues including release, with feature tests inside each and retained peer review.
4	ตอนนี้สามารถเริ่มเลย ได้ไหม	Began the contract work item, checked GitHub/main, created isolated branch/worktree and drafted seven linked planning/evidence documents.
5	ขอ UI สวยๆ และให้ ตรงใจทีนะ	Strengthened UI contract with concrete dimensions/hierarchy, queue table/mobile cards, separate private/public composers, narrow Admin UI and visual checklist.
6	แก้เลยแล้วผมต้องรีว ของเพื่อนครวยกแซ ทใหม่	Addressed Datakung's 2026-09-12 board/document mismatch review: return #26 to Backlog, correct #25 workflow and review records, preserve the separate local authentication draft, and prepare the correction for re-review. Recommended a separate conversation for reviewing the partner's repository.
7	เพื่อนส่งแกมาแล้ว	Read the actual peer findings, fixed dirty navigation loss and ambiguous browser assertions, and added regression coverage.
8	ใส่ให้ผมเลยได้ไหม	Drafted the Reflection below using recorded project events, explicitly retaining student review before submission.
9	ทำ issue ต่อเลย	Continued #29 with integrated checks, responsive/error-state evidence, real API failure/rollback coverage and a nine-part submission draft.

ร่าง Reflection สำหรับ Answer Part 4

ร่างโดย Codex ตามคำขอของผู้ใช้ "ใส่ให้ผมเลยได้ไหม" เมื่อ 2026-09-25 โดยอิงจากเหตุการณ์ที่บันทึกไว้ในโครงการ ผู้ใช้ยังต้องอ่านและรับข้อความให้ตรงกับประสบการณ์และความเข้าใจของตนก่อนส่ง ร่างนี้ไม่ใช่หลักฐานว่าผู้ใช้ได้ตรวจโค้ดหรือทดสอบด้วยตนเองแล้ว

การทำ Lab 3 แสดงให้เห็นว่าการพัฒนาระบบไม่ได้จบแค่หน้าเว็บแสดงผลได้ แต่ต้องมีข้อกำหนด สิทธิ์ของผู้ใช้ และหลักฐานการทดสอบที่สอดคล้องกัน เช่น Requester ควรเข้าถึงเฉพาะงานของตนเองและข้อความสาธารณะ ส่วน IT Staff และ Administrator มีหน้าที่และสิทธิ์ต่างกัน การซ่อนปุ่มในหน้าเว็บอย่างเดียวยังไม่เพียงพอ ต้องตรวจสอบสิทธิ์ที่ API ด้วย

AI ช่วยอ่านและสรุปโจทย์ วางแผน Issues ร่าง specification และช่วยพัฒนาโค้ด ชุดทดสอบ และเอกสารตามขอบเขตของแต่ละงาน การจัดงานเป็น 6 Issues ทำให้รวมการพัฒนากับการทดสอบของแต่ละส่วนไว้ด้วยกัน และยังคงให้เพื่อนรีวิวก่อนรวมโค้ด อย่างไรก็ตาม โค้ดและเอกสารที่ AI สร้างยังต้องตรวจเทียบกับโจทย์และผลการทำงานจริง ไม่ควรถือว่าถูกต้องเพียงเพราะ AI รายงานว่าทำเสร็จ

ตัวอย่างที่ชัดเจนคือการรีวิว PR #34 เพื่อนพบว่าการออกจากหน้าจัดการผู้ใช้ขณะมีข้อมูลที่ยังไม่ได้บันทึกอาจทำให้ข้อมูลในฟอร์มหาย จึงมีการเพิ่มการยืนยันก่อนออกจากหน้าผ่านเมนูและปุ่ม Back/Forward พร้อมเพิ่ม regression tests อีกประเด็นคือ browser test ตรวจข้อความสถานะกว้างเกินไป จึงแก้ไขตรวจสอบข้อความสำเร็จของการทำงานนั้นโดยตรง เหตุการณ์นี้แสดงให้เห็นว่าการรีวิวช่วยพบทั้งปัญหาของระบบและจุดอ่อนของชุดทดสอบได้

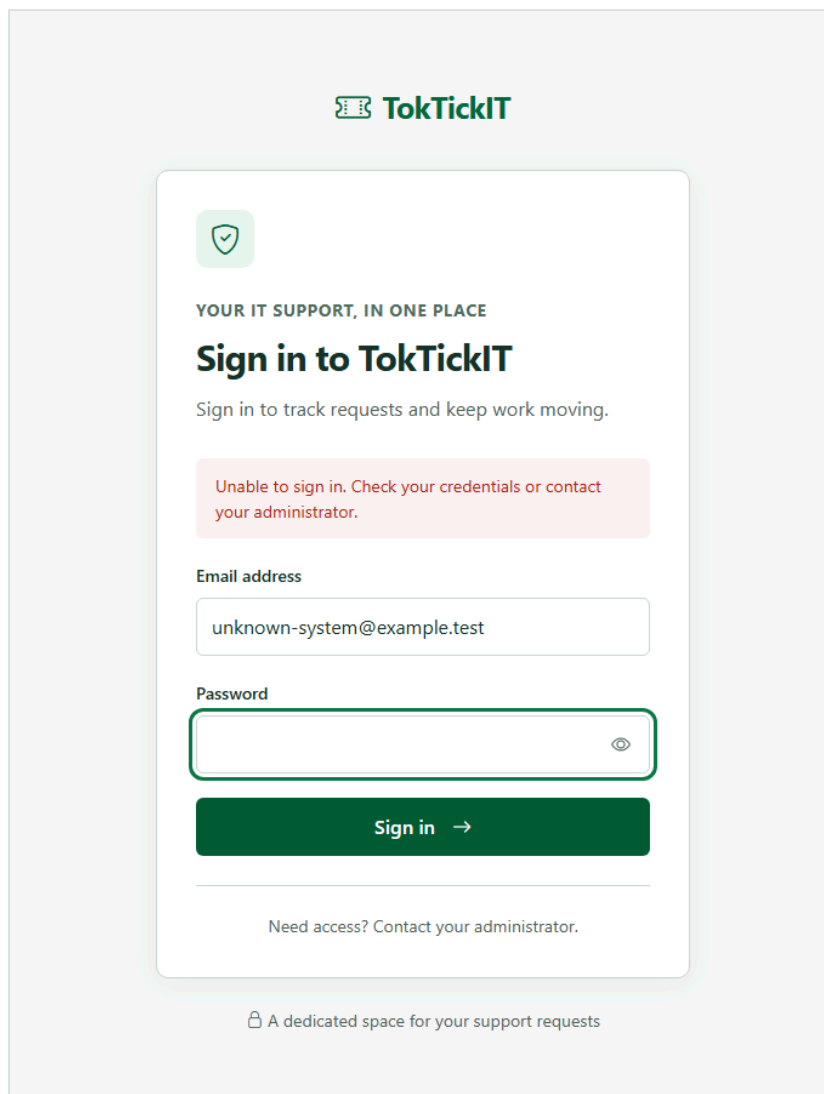
ประเด็นที่ควรนำไปใช้ต่อไปคือการเริ่มจากข้อกำหนดที่ตรวจสอบได้ ทดสอบทั้งกรณีสำเร็จและกรณีผิดพลาด และบันทึกผลตามที่เกิดขึ้นจริง โดยแยกงานที่ทำแล้ว งานที่ผ่านการทดสอบ และงานที่เพื่อนอนุมัติออกจากกัน ผู้ส่งงานยังต้องอธิบายเหตุผลของการออกแบบ ตรวจสอบความถูกต้องของรายงาน และรับผิดชอบผลงานที่ส่ง แม้จะมี AI ช่วยเขียนโค้ดและเอกสารก็ตาม

Answer Part 5

Authentication

Real browser and API tests cover valid/invalid/inactive credentials, first-login password change, role landing, logout and direct access after invalidation. Busy/failure presentation states use explicitly labelled controlled responses; API failure/authorization checks are separate evidence.

Login validation



The screenshot displays the TokTickIT login interface. At the top, the TokTickIT logo is visible. Below it, a green shield icon with a checkmark is shown. The text "YOUR IT SUPPORT, IN ONE PLACE" is followed by the heading "Sign in to TokTickIT". A subtext reads "Sign in to track requests and keep work moving." A red error message states: "Unable to sign in. Check your credentials or contact your administrator." Below this, the "Email address" field contains "unknown-system@example.test". The "Password" field is empty and has a green border. A green "Sign in →" button is positioned below the password field. At the bottom, a link says "Need access? Contact your administrator." and a footer note reads "A dedicated space for your support requests".

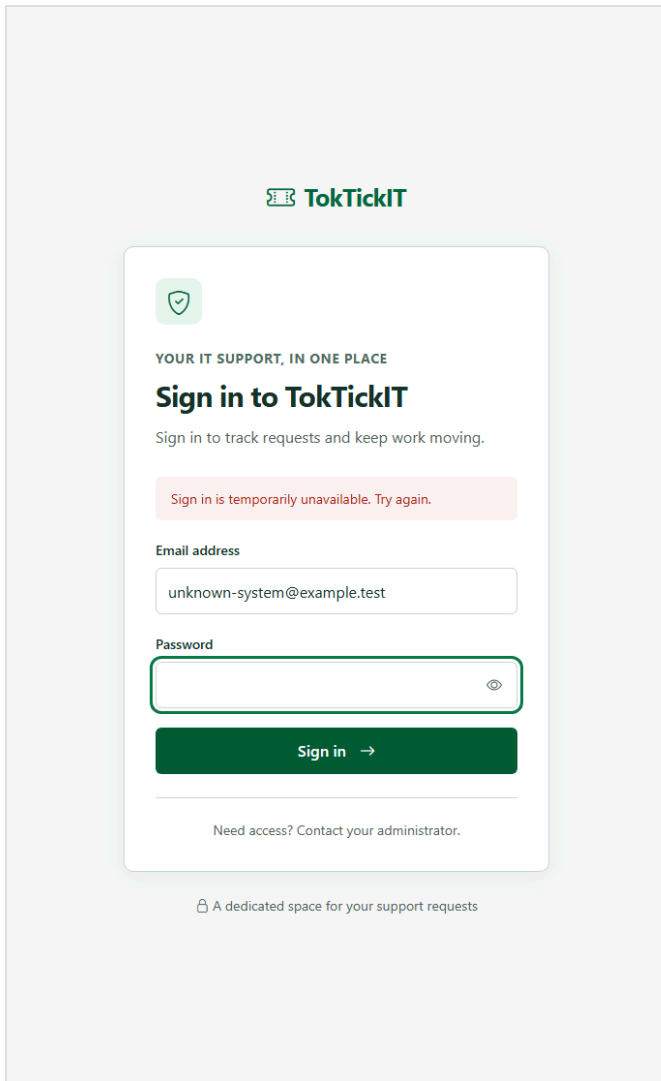
Desktop - invalid login

Labelled detail excerpt

[Full-size capture](#)

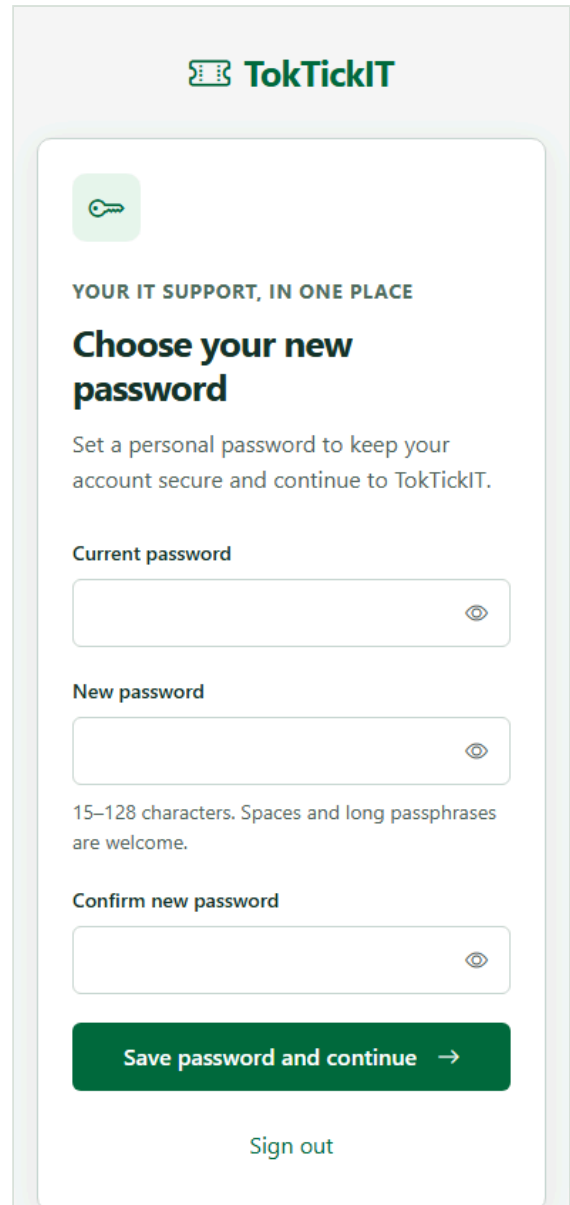
Actual final-main capture 2026-09-27T12:21:40.282Z; source b3a65949f3fa. Synthetic fixture data.

Password change and recovery



The screenshot shows the TokTickIT sign-in interface on a tablet. At the top is the TokTickIT logo. Below it is a green shield icon with a checkmark. The text reads: "YOUR IT SUPPORT, IN ONE PLACE", "Sign in to TokTickIT", and "Sign in to track requests and keep work moving." A red error message states: "Sign in is temporarily unavailable. Try again." Below this are input fields for "Email address" (containing "unknown-system@example.test") and "Password" (empty). A green "Sign in →" button is at the bottom. A link "Need access? Contact your administrator." is below the button. At the very bottom, a small icon and text say: "A dedicated space for your support requests".

Tablet - simulated failure
Labelled detail excerpt
[Full-size capture](#)



The screenshot shows the TokTickIT password change interface on a mobile device. At the top is the TokTickIT logo. Below it is a green key icon. The text reads: "YOUR IT SUPPORT, IN ONE PLACE", "Choose your new password", and "Set a personal password to keep your account secure and continue to TokTickIT." There are three input fields: "Current password", "New password", and "Confirm new password", each with a toggle icon. Below the "New password" field, text reads: "15–128 characters. Spaces and long passphrases are welcome." A green "Save password and continue →" button is at the bottom. A "Sign out" link is at the very bottom.

Mobile - mandatory password change
Labelled detail excerpt
[Full-size capture](#)

Actual final-main capture 2026-09-27T12:21:40.282Z; source b3a65949f3fa. Synthetic fixture data. Labelled simulated responses.

Answer Part 6

Queue and ticket lookup

Queue query semantics, page/sort/owner filters and authorization are verified by real API tests. Browser evidence checks filtering, results, empty/no-results/failure feedback and responsive geometry. Realistic synthetic tickets contain varied priority, owner and state values.

Desktop queue

TokTickIT

Ticket Queue

Alex Morgan

IT Staff

[Password](#)

[Logout](#)

SUPPORT WORKSPACE

17 matching tickets

Ticket Queue

Find and prioritize support requests.

Search tickets

Ticket number, summary or description

Search

Status

IT Priority

Category

Owner

All statuses

All priorities

All categories

All owners

Sort by

Order

Tickets per page

Apply filters

Clear filters

Last updated

Descending

10

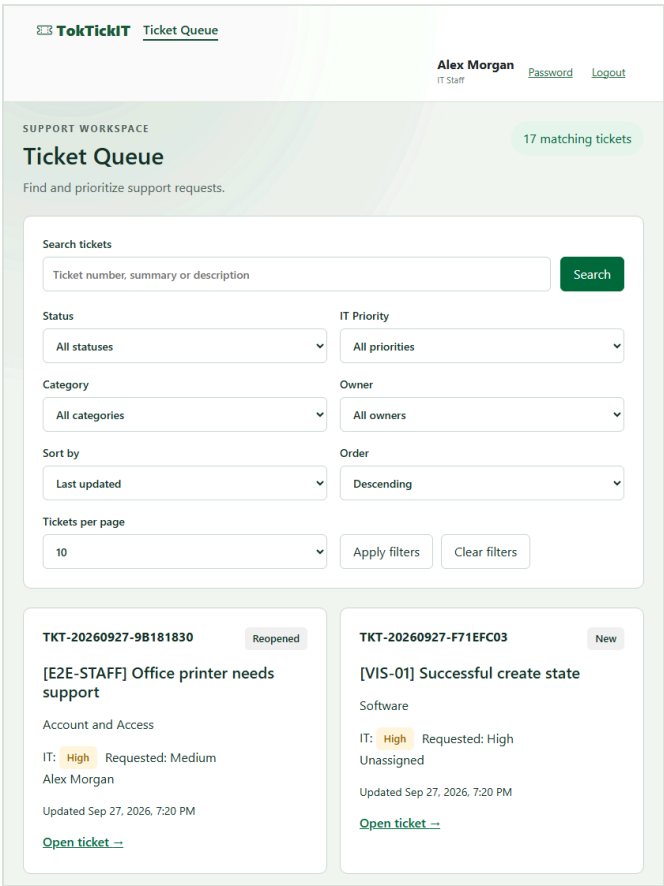
Ticket	Category	Priority	Status	Owner	Updated
TKT-20260927-9B181830 [E2E-STAFF] Office printer needs support	Account and Access	High Requested: Medium	Reopened	Alex Morgan	Sep 27, 2026, 7:20 PM
TKT-20260927-F71EFC03 [VIS-01] Successful create state	Software	High Requested: High	New	Unassigned	Sep 27, 2026, 7:20 PM
TKT-20260927-D596BD48 [VIS-01] Attachment lifecycle evidence	Software	High Requested: High	New	Unassigned	Sep 27, 2026, 7:20 PM
TKT-20260927-F04B2620 [RESP-mobile] Long requester-visible summary Long requester-visible summary Long requester-visible summary	Software	High Requested: High	New	Unassigned	Sep 27, 2026, 7:20 PM

Desktop - realistic queue
Labelled detail excerpt
[Full-size capture](#)

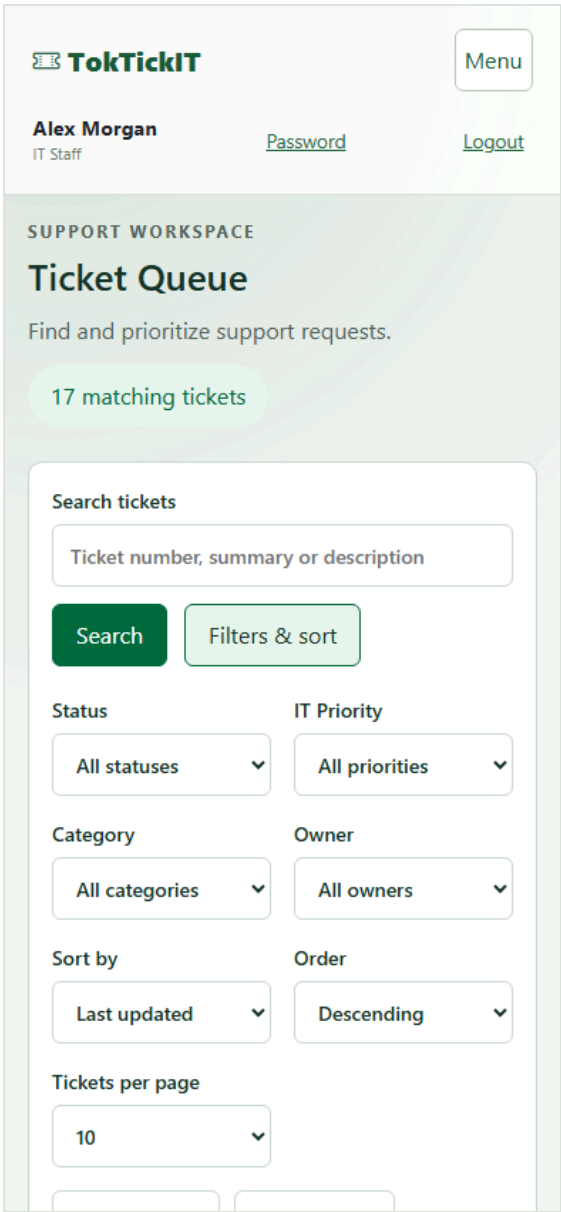
Actual final-main capture 2026-09-27T12:21:40.282Z; source b3a65949f3fa. Synthetic fixture data.

Tablet and mobile queue

Empty/no-results and explicitly simulated failure captures are included in the full image index.



Tablet - ticket cards
Labelled detail excerpt
[Full-size capture](#)



Mobile - filters and queue
Labelled detail excerpt
[Full-size capture](#)

Actual final-main capture 2026-09-27T12:21:40.282Z; source b3a65949f3fa. Synthetic fixture data.

Answer Part 7

Ticket workflow and role protection

API/browser tests verify claim/reassignment, IT priority, all status edges, version conflicts, terminal restrictions, public/private separation, retained attachment access and Requester resolution indication. A real transaction rollback case verifies that a failed append leaves no persisted comment or ticket timestamp update.

Staff ticket operations

TokTickIT

Ticket Queue

Alex Morgan

IT Staff

Password

Logout

← Back to Queue

TKT-20260927-7963C732

New

[VIS-desktop] Printer support with a long descriptive summary for responsive verification

Updated Sep 27, 2026, 7:21 PM

Ticket information

Requester

Jennifer Anderson

e2e.jennifer@example.test

Created

Sep 27, 2026, 7:21 PM

Category

Software

Related System

Customer Portal

Requested Priority

High

IT Priority

High

Description

Deterministic requester journey evidence for the Lab 2 quality gate.

Attachments

synthetic-printer-diagnostic.png

Download

Manage ticket

Owner

Unassigned

Claim ticket

Assign to

Unassigned

Assign / Reassign

IT Priority

High

Requested priority stays unchanged.

Save priority

Next status

Choose next status

Desktop - ticket operations
Labelled detail excerpt
[Full-size capture](#)

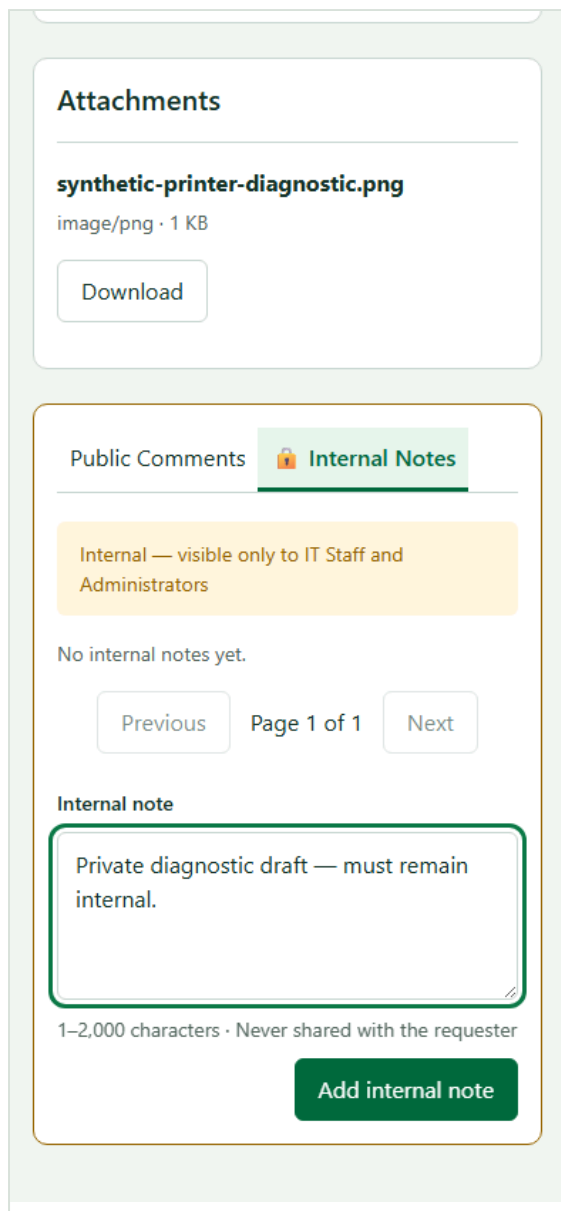
Actual final-main capture 2026-09-27T12:21:40.282Z; source b3a65949f3fa. Synthetic fixture data.

TOKTICKIT / LAB 03 / FINAL-MAIN EVIDENCE - STUDENT ACCEPTANCE PENDING

23 / 30

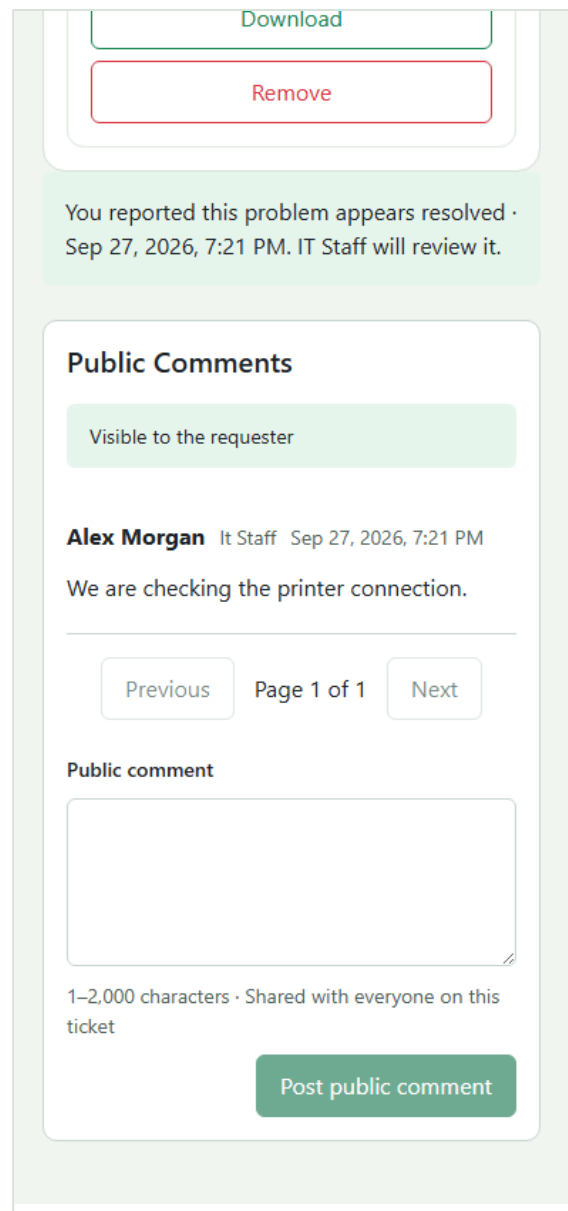
Private notes and Requester indication

Full-size captures include attachment controls. The index additionally includes restricted Admin views. Direct API tests establish authorization.



The interface shows an 'Attachments' section with a file named 'synthetic-printer-diagnostic.png' (image/png, 1 KB) and a 'Download' button. Below this is a tabbed interface with 'Public Comments' and 'Internal Notes'. The 'Internal Notes' tab is active, showing a note that is 'Internal — visible only to IT Staff and Administrators'. The note content is 'Private diagnostic draft — must remain internal.' and it has a character count of '1–2,000 characters · Never shared with the requester'. There is an 'Add internal note' button at the bottom.

Mobile - private composer
Labelled detail excerpt
[Full-size capture](#)



The interface shows a 'Download' button and a 'Remove' button. Below these is a green notification box stating: 'You reported this problem appears resolved · Sep 27, 2026, 7:21 PM. IT Staff will review it.' Below the notification is a 'Public Comments' section with a tab 'Visible to the requester'. A comment by 'Alex Morgan' (It Staff) dated 'Sep 27, 2026, 7:21 PM' says 'We are checking the printer connection.' There are 'Previous', 'Page 1 of 1', and 'Next' navigation buttons. Below the comment is a 'Public comment' input field with a character count of '1–2,000 characters · Shared with everyone on this ticket' and a 'Post public comment' button.

Requester - public conversation and indication
Labelled detail excerpt
[Full-size capture](#)

Actual final-main capture 2026-09-27T12:21:40.282Z; source b3a65949f3fa. Synthetic fixture data.

Answer Part 8

Administrator user management

Account lifecycle tests cover directory/search, create/edit, normalized unique email, exactly one role, activity, initial-password reset and mandatory change. Concurrent API tests protect the last active Admin and active ticket owners. Dirty-navigation browser regressions cover menu and native Back/Forward cancellation.

Directory and creation validation

TokTickIT

Users

Ticket Lookup

Taylor Admin

Administrator

Password

Logout

ADMINISTRATION

Users

A well-organized team starts with the right access.

+ Create user

Search users

Search name or email

Role filter

All roles

Search

17 accounts in your workspace

NAME	EMAIL	ROLE	STATUS	
A Alex Morgan	e2e.staff@example.test	It Staff	Active	Edit
A Alex Rivera	alex.staff@example.test	It Staff	Active Password change required	Edit
A Archived Requester	archived.requester@example.com	Requester	Inactive Password change required	Edit
A Archived Staff	archived.staff@example.test	It Staff	Inactive Password change required	Edit
I Initial Password Evidence	e2e.visual-initial@example.test	It Staff	Active Password change required	Edit

← Back to Users

WELCOME SOMEONE NEW

Create user

One account, one role. A clear place to start.

Name

Enter a name between 1 and 100 characters.

Email

Enter a valid email address.

Role

Requester

Active account

Inactive users cannot sign in. Changing access ends existing sessions.

The user must change their initial password at first sign in.

Initial password

Desktop - directory and creation validation
Labelled detail excerpt
[Full-size capture](#)

Actual final-main capture 2026-09-27T12:21:40.282Z; source b3a65949f3fa. Synthetic fixture data.

Editor and password reset

The image shows a tablet view of the 'TokTicketIT' user management interface. At the top, there's a header with the logo, 'Users' tab, and 'Ticket Lookup' link. On the right, the user 'Taylor Admin' is logged in as an 'Administrator', with links for 'Password' and 'Logout'. The main content area has a 'Back to Users' link and a 'MANAGE ACCOUNT' section titled 'Edit user'. Below this, a message states 'Keep account details and access up to date.' The form includes fields for 'Name' (Taylor Admin), 'Email' (e2e.admin@example.test), and 'Role' (Administrator). There's a checkbox for 'Active account' which is checked, with a note 'Your own account must stay active.' At the bottom of the form are 'Cancel' and 'Save changes' buttons. A 'Password access' section at the very bottom has a message 'Set a new initial password if this user needs help signing in.' and a 'Set new initial password' button.

Tablet - account editor
[Full-size capture](#)

The image shows a mobile view of the 'TokTicketIT' interface, specifically a password reset dialog. The header shows the logo and a 'Menu' button. The user 'Taylor Admin' is logged in as an 'Administrator', with links for 'Password' and 'Logout'. The dialog is titled 'ACCOUNT SECURITY' and 'Set a new initial password'. It contains a message: 'All existing sessions for Taylor Admin will end. They must change this password when they next sign in.' Below this is a yellow callout box stating 'This is your account. You will return to sign in after saving.' The form has two input fields: 'Initial password' and 'Confirm initial password'. The 'Initial password' field has a 'Show' button next to it. A message below the first field says 'Use 15-128 characters. Share this initial password with the user securely.' At the bottom are 'Cancel' and 'Set initial password' buttons.

Mobile - reset dialog
Labelled detail excerpt
[Full-size capture](#)

Actual final-main capture 2026-09-27T12:21:40.282Z; source b3a65949f3fa. Synthetic fixture data.

Answer Part 9

UI specification and final visual evidence

Capture source b3a65949f3fad3c84ffabbe01707db0d929686f0; timestamp 2026-09-27T12:21:40.282Z. All 109 screenshot hashes match. Viewports: 1440x900, 834x1112, 390x844 and 320x900. [Complete image index](#) and [final-main provenance](#). Labelled excerpts preserve readability; original full-page PNGs remain linked.

Rendered complete screen/design/responsive specification, with current inspection recorded below. [Source document](#).

UI specification and visual inspection

The screen definitions below retain the reviewed design contract. Final-main image inspection and human acceptance are reported separately after the specification.

1. Visual direction and reusable components

Use a quiet off-white canvas, white cards, restrained borders, deep-green navigation, generous spacing and strong typography. Prioritize a clear page title, task context and one dominant action per panel. Avoid excessive shadows, gradients, decorative charts, oversized marketing copy and crowded spreadsheets. Preserve the existing TokTickIT wordmark; no new logo or imagery is needed.

Inherited tokens from [Lab 2 UI specification](#): primary #006B3C, hover #005A33, secondary/focus #0B7A46, pale green #EAF6EF, page #F5F7F6, surface #FFFFFF, text #17352A, muted #52665E, border #CCD8D2, readonly #F0F3F1, error #B42318 / #FEF3F2, warning #9A6700 / #FFF7E0. No hard-coded alternative theme colors in feature screens. Semantic badges combine these existing tokens with explicit labels/icons.

Element	Contract
Content width	Queue/admin max 1200px; detail max 1120px; login/password card max 440px. Center content.
Header	64px desktop; brand, role navigation, current user/role, Logout. Mobile allows two clean rows/menu without clipping.
Page spacing	32px desktop, 24px tablet, 16px mobile; 24px between sections and 16px inside related groups.
Type	Existing Inter/Segoe UI/system stack; body 16px/1.5, labels/helper text >=14px; page titles 30px desktop/26px mobile.
Surfaces	Cards 10px radius, 1px neutral border; use existing subtle shadow sparingly. Buttons/inputs 6px radius.
Controls	>=44px height and 44x44 touch targets; visible labels; no unlabeled icon-only primary action.
Tables	Calm header, 14-16px text, >=64px ticket rows, clear hover/focus; row links remain explicit.
Focus/error	2-3px visible token-based focus ring; inline linked field errors; summary/banner announces submit failures.

Extract/reuse ApplicationShell, PageHeader, FormField, Button, StatusBadge, PriorityBadge, RoleBadge, StatePanel, ConfirmationDialog, Pagination and AttachmentList from established styles. Share ticket information blocks between Requester and staff detail. Components accept permitted actions/data; backend authorization remains authoritative. Avoid three duplicated detail forms with divergent validation.

2. Routes and navigation

Route	Screen / permission
/login	Public login card
/change-password	Any authenticated role; only application route for initial-password user
/tickets, /tickets/new, /tickets/:ticketId	Requester own workflows
/staff/tickets, /staff/tickets/:ticketId	IT Staff queue/detail; Administrator secondary Ticket Lookup with narrow rights
/admin/users	Administrator user management

Landing pages: Requester My Tickets; IT Staff Ticket Queue; Admin Users. Admin secondary navigation says Ticket Lookup, not My Queue. Current-user bootstrapping shows a neutral busy shell before protected content; never flash another role's controls. Preserve only a validated internal permitted intended route after login; otherwise use the role landing page. No open redirects.

Legacy `/select-requester` redirects to login. Remove Development Requester selector/notice, Change Requester, X-Requester-Id headers and persisted identity state. Logout first revokes server access, then clears all protected caches/drafts/creation keys and returns to login. On failed logout, show retry and do not claim successful revocation. On 401 from any protected request, clear protected data and return to login with concise session-expired feedback. 403 `PASSWORD_CHANGE_REQUIRED` navigates to password change; other 403 shows forbidden without stale content.

3. Login and Change Password

Login: centered white card with brand, "Sign in to TokTickIT", brief helper, Email, Password with accessible show/hide button, and full-width Sign In. No social-login, registration or forgotten-password email links. Use autocomplete username/current-password; allow paste. Empty/invalid email fields get inline errors. Busy button reads "Signing in..." and prevents double submission. Generic credential failure does not identify inactive versus unknown users. Rate-limit feedback shows wait/retry guidance from Retry-After. Network failure retains email; clear password on success/navigation and never persist it.

Change Password: same visual card, heading "Choose your new password", explanation of initial-password requirement, Current Password, New Password, Confirm Password, always-visible 15-128 character passphrase guidance and primary "Save password and continue". New fields use autocomplete new-password. Show mismatch/length/current-password validation where it occurs. Initial-password users have Logout available but no application navigation or skip action. Successful change opens the role landing page. Ordinary voluntary password change uses the same form and may offer a Back action for full sessions.

4. Requester continuity

Preserve Create Ticket/My Tickets/Attachment usability and field validation from Lab 2. Current name comes from the session. New IT Priority is displayed as a read-only badge equal to Requested Priority initially. Requester detail contains grouped ticket metadata, description, Attachments and a Public Comments section; no Internal Notes tab, badge, count or empty placeholder.

In allowed states, show a secondary "Problem appears resolved" action with a confirmation explaining "IT Staff will review this and formally resolve or close your ticket." On success display "You reported this problem appears resolved" with server time; keep the actual status badge unchanged. Disable the repeat action with explanatory text. CLOSED/CANCELLED conversations show readable history and "This ticket is read-only"; existing Requester attachment actions remain available under inherited ownership rules.

5. IT Staff Ticket Queue

Page header: "Ticket Queue", short context "Find and prioritize support requests", and count of matching results. No create-ticket action for staff. A search field spans useful width with explicit label and clear action; filter toolbar contains Status, IT Priority, Category and Owner (All, Unassigned, Assigned to me, eligible named owner), plus Sort and Clear Filters. Queries apply on Search/Apply or Enter, not every keystroke; changes reset page to 1. For Admin lookup omit owner-selection lookup and present All/Unassigned/Assigned to me only; API UUID filtering remains available to authorized queries.

Desktop table uses six columns to avoid a mega-grid:

Column	Display
Ticket	Green linked Ticket Number and Summary below; summary wraps to two lines; accessible full text in the detail link
Category	Plain readable label
Priority	IT Priority badge prominent; secondary labelled "Requested: High" (or actual value)
Status	Text/icon status badge with enough width for Waiting for Requester
Owner	Name or neutral "Unassigned"; historical inactive owner explicitly labelled
Updated	Localized date/time with full timestamp available; no ambiguous relative-only time

Created date and Related System belong in detail; sorting by created date remains in the Sort control. The result range and page-size control sit below the table with Previous/Next and page numbers. Stable row heights, aligned cells and restrained badge colors matter more than maximum density. Do not make the whole row an inaccessible click target.

At tablet widths stack the toolbar and use ticket cards if six columns would squeeze labels. Below 768px always use cards: number/status in first row, summary, category, requested/IT priority, owner/update, explicit "Open ticket" link. Show filters in a collapsible inline panel with aria-expanded; no horizontal page scrolling.

States: loading skeleton matching result layout; empty queue "No tickets yet"; filtered no-results with Clear Filters; failure panel with Retry; forbidden with a permitted-home link. Failed queries never silently display old results under new filter labels. On a background refresh failure, retained results must be labelled as previous results and kept bound to their original query.

6. IT Staff Ticket Detail

Top: breadcrumb Back to Queue, Ticket Number and summary, status badge and updated timestamp. Desktop grid uses approximately 2fr content / 1fr operational card; narrow screens stack ticket content, operational controls, attachments and conversation in that order. No sticky panel may obscure focus or content.

Content card: requester, created date, category, related system, requested priority, description. Historical data are read-only text on subtle readonly surfaces, not disabled low-contrast inputs. Long descriptions/filenames wrap safely.

Operational card: owner, "Claim ticket" if unassigned, owner picker + confirmed Assign/Reassign, IT Priority selector + Save, permitted-next-status selector + Update. Keep each operation's busy/success/error feedback local. Selecting values does not immediately mutate the server. Show only valid next statuses, but also explain why an action is unavailable (for example "Assign an active owner before starting work"). Confirm resolve/close/reopen/cancel with the ticket number and exact target state. Reassignment shows old/new owner. Cancelling a dialog leaves values/data unchanged.

Admin detail uses the same read-only content and conversation/attachment views, with only IT Priority editable. Never show Claim, owner editing, status editing or a conversation composer for Admin. This visibly implements the narrow authorization matrix.

Conversation uses separate "Public Comments" and "Internal Notes" tabs for Staff/Admin. A Public composer carries the label "Visible to the requester"; Internal Notes shows a lock icon, amber-tinted header and "Internal - visible only to IT Staff and Administrators". Separate draft state per tab; switching never copies private text to the public draft. Post buttons read "Post public comment" and "Add internal note". Display author, role and timestamp on each entry. Render plain text, never raw HTML. Keep tabs keyboard operable; show the active tab in text/underline, not just color.

For uncertain post failures retain the relevant draft and reload conversation before offering Retry; no automatic append retry. For version conflict preserve the attempted selection separately, show "This ticket changed. Reload the latest details before trying again", and require a fresh deliberate submit after reload. Never silently overwrite a colleague's work.

Attachments reuse the existing list: safe filename/type/size, active Download, Removed/Unavailable labels, no preview. Staff/Admin have no upload/remove controls. Requester indication appears as a pale-green callout distinct from the formal status.

7. Minimal Administrator User Management

Page header: "Users", brief helper, primary "Create user". Search by name/email and one optional Role filter; no dashboard cards, bulk actions, export, delete, departments or mandatory pagination.

Desktop: table columns Name, Email, Role, Status, Edit; editing/creation opens a right-hand panel around 400px wide with a clearly labelled close/cancel action. At tablet/mobile use a full-width form view and Back to Users, avoiding two narrow columns. Table becomes cards on mobile, with a visible Edit button for every item.

Create form: Name, Email, single Role select, Active switch with textual Active/Inactive state, Initial Password with show/hide and confirmation. UI confirmation is compared before sending the API's initialPassword field. Save User/Cancel at the bottom. Explain initial password must be communicated manually and changed on first login. No "send password reset email" checkbox from the sample image.

Edit form: same basic fields except password; separate "Set new initial password" action opens a small confirmation dialog with initial/confirm fields. Explain it signs out existing sessions and forces a password change. An Admin's own Active switch is locked active with helper text; backend still enforces it. Last-admin and active-ticket-owner failures show the safe reason next to the attempted role/activation control and preserve entered basic data. No deletion button.

After create/edit refresh the list from server data and announce success. Reset clears password inputs immediately after success and shows no password in list/toast/log. If own role/reset revokes the session, return to login with an accurate explanation. Conflicts require reload/review; no silent overwrites. Dirty non-password form closes require discard confirmation. Password drafts clear on cancel/unmount.

8. Required modes, feedback and accessibility

Main modes are login/change-password, list, view, create and edit. Loading/validation/conflict are feedback within these modes, not invented formal business states. Every implemented screen must demonstrate meaningful busy, success, safe failure and forbidden behavior; lists additionally demonstrate empty/no-results; details demonstrate not-found; versioned forms demonstrate conflict.

Use semantic headings and landmarks, labelled inputs, aria-describedby errors, aria-invalid and live status messages. On invalid submit focus the first invalid field. Dialogs support Escape where cancellation is permitted, focus trapping, labelled title and focus restoration. Menus expose expanded state. Statuses/roles/priorities contain readable text; icons complement it. Keep normal text contrast consistent with inherited WCAG AA design targets. Check browser zoom and long content manually; automated DOM assertions do not prove visual quality.

9. Responsive and visual evidence

Breakpoints: desktop ≥ 992 px; tablet 768-991px; mobile < 768 px. Verify 1440x900, 834x1112, 390x844 plus a narrow 320px overflow check. Major screenshot groups under `artifacts/lab-03/screenshots/`:

Folder	Required scenes at desktop/tablet/mobile
authentication/	login-ready, login-invalid, change-password, authenticated role navigation
staff-queue/	realistic results and responsive filters/pagination; supplementary empty/no-results/failure
staff-ticket-detail/	operational controls + Public Comments, clearly distinct Internal Notes, conflict/validation/terminal states, Admin restricted view
user-management/	user list, create/edit, initial-password dialog, safety validation
requester/	owned detail with public conversation/resolution indication and attachment continuity

Use consistent names `<viewport>-<scene>.png`; routine test captures stay in ignored test-results, curated captures use an explicit evidence command. Screenshot fixtures are synthetic, show no passwords/tokens and have enough rows/text to test realistic density.

Integrated capture uses `npm run test:e2e:capture:lab3` and groups the required scenes under `artifacts/lab-03/screenshots/system/{system-states,staff-workflow,user-management}/`. Its manifest is the authoritative filename index. `system-states` includes authentication, Requester, conflict/terminal and restricted Admin scenes; inherited feature captures retain their original names. Explicitly simulated busy/failure/empty scenes are labelled in filenames. The integrated browser check found a confirmation keyboard-cycle defect; shared confirmation and reset dialogs now explicitly wrap focus and preserve Escape/opener behavior. The final human checklist below remains distinct from agent inspection recorded in `system-verification.md`.

Inspection and acceptance

Final-main visual inspection

Source: `b3a65949f3fad3c84ffabbe01707db0d929686f0`. Inspection performed by Codex on 2026-09-27 after the complete final-main browser capture. This records agent inspection, not an invented student action.

- [x] Desktop 1440px queue: aligned filters/table, readable priority/owner/status information and pagination; no overlapping content in the opened capture.
- [x] Tablet 834px editor and create-validation screen: clear labels, account safety helper, validation messages and primary action; no clipping in the opened captures.
- [x] Mobile 390px private detail: stacked operations, distinct amber private composer, readable attachment controls and visible draft focus.
- [x] Mobile Requester indication: public-only history, attachment controls, separate indication and unchanged formal status presentation.
- [x] Narrow 320px reset/create-validation: inputs, error text, show-password control and actions remain within the page; native dialog focus indication is visible.
- [x] Desktop simulated login failure: safe recovery message and visible focused field; explicitly a simulated presentation state.
- [x] All 17 browser journeys pass, including four-width no-overflow checks, keyboard focus cycling, Escape/opener restoration, restricted role controls and dirty-navigation recovery.
- [x] Every one of the 109 captured image SHA-256 values matches the raw manifest. All fixture identities and files are synthetic.
- [] Student's own final walkthrough and native browser zoom check: awaiting explicit confirmation.

Eight full-page images were opened for the visual observations above. The automated geometry assertions cover additional captured scenes; that is distinct from claiming that every screenshot was manually inspected. The inspection does not establish exhaustive WCAG conformance.

Student Reflection reading/adaptation and final human visual acceptance remain pending. Do not mark Issue #30 Done or submit this copy until those steps are recorded.